Module 09: Active Directory Penetration Testing

```
# Exercise 04: Performing Active Directory Enumeration using PowerShell
```

Scenario

PowerShell script modules such as **PowerView** (`PowerView.ps1`) and native RSAT Active Directory cmdlets (`ActiveDirectory`) provide comprehensive situational awareness during Windows domain assessments. PowerView queries Active Directory via LDAP, extracting domain metadata, computer accounts, domain groups, Kerberos policies, password last set timestamps, and `useraccountcontrol` flags.

Identifying domain accounts configured with **"Do not require Kerberos preauthentication"** (UAC flag `DONT_REQUIRE_PREAUTH` / `528384` or bit `0x10000`) enables **AS-REP Roasting** attacks. An unauthenticated attacker can request an AS-REP ticket for such users and attempt offline cracking against the ticket's encrypted section without needing a domain user password to initiate the request. In this exercise, we configure execution policy bypass in PowerShell on **2019DC**, import `PowerView.ps1` , enumerate AD domain policies and user accounts, configure AS-REP roasting eligibility on user `CPENT` , and analyze `useraccountcontrol` properties alongside native `ActiveDirectory` cmdlets.

Objective

The objective of this lab is to help students learn how to:
- Bypass PowerShell script execution policies using **set-executionpolicy Bypass**
- Load PowerView module into PowerShell session via **import-module .\PowerView.ps1**
- Enumerate core domain details using **Get-Domain**
- Retrieve domain computer assets (**Get-domaincomputer**) and domain groups (**Get-domaingroup**)
- Extract domain password and lockout policies using **Get-domainpolicy**
- Track password last set timestamps in chronological order via **Get-NetUser -Properties pwdlastset**
- Enumerate domain user properties (**Get-NetUser**) and identify user UserPrincipalNames (e.g., `jdoe` : **jdoe@lpt.com**)
- Disable Kerberos Pre-authentication in Active Directory Users and Computers (ADUC) for user `CPENT`
- Inspect `useraccountcontrol` flags in PowerView to detect AS-REP Roasting misconfigurations
- Import and inspect native PowerShell RSAT modules using **Import-Module ActiveDirectory** and **Get-Command -Module ActiveDirectory**

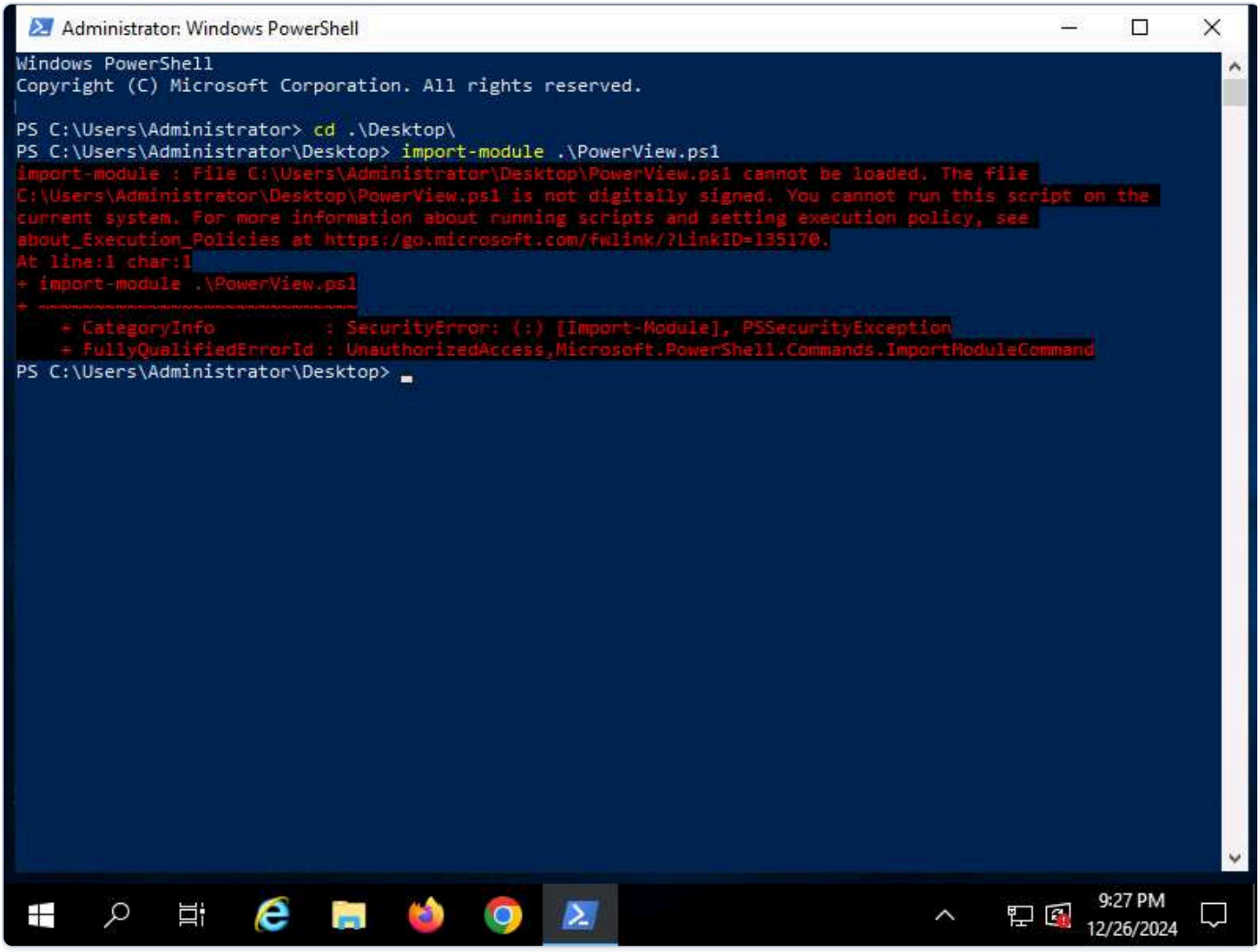
Task 1: Execute PowerView Domain Enumeration & Identify Kerberos Pre-authentication Misconfigurations

In this task, we log into **2019DC** as Domain Administrator (**LPT\Administrator** / **Pa$$w0rd**), bypass PowerShell execution policy, import `PowerView.ps1` , query domain objects, disable Kerberos Pre-authentication for `CPENT` , and analyze `useraccountcontrol` flags.

Lab Tasks

1. Switch to **2019DC** machine and log in as Domain Administrator (**LPT\Administrator** / **Pa$$w0rd**).
2. Open Windows PowerShell, navigate to Desktop (`cd Desktop`), and attempt loading PowerView:
   import-module .\PowerView.ps1

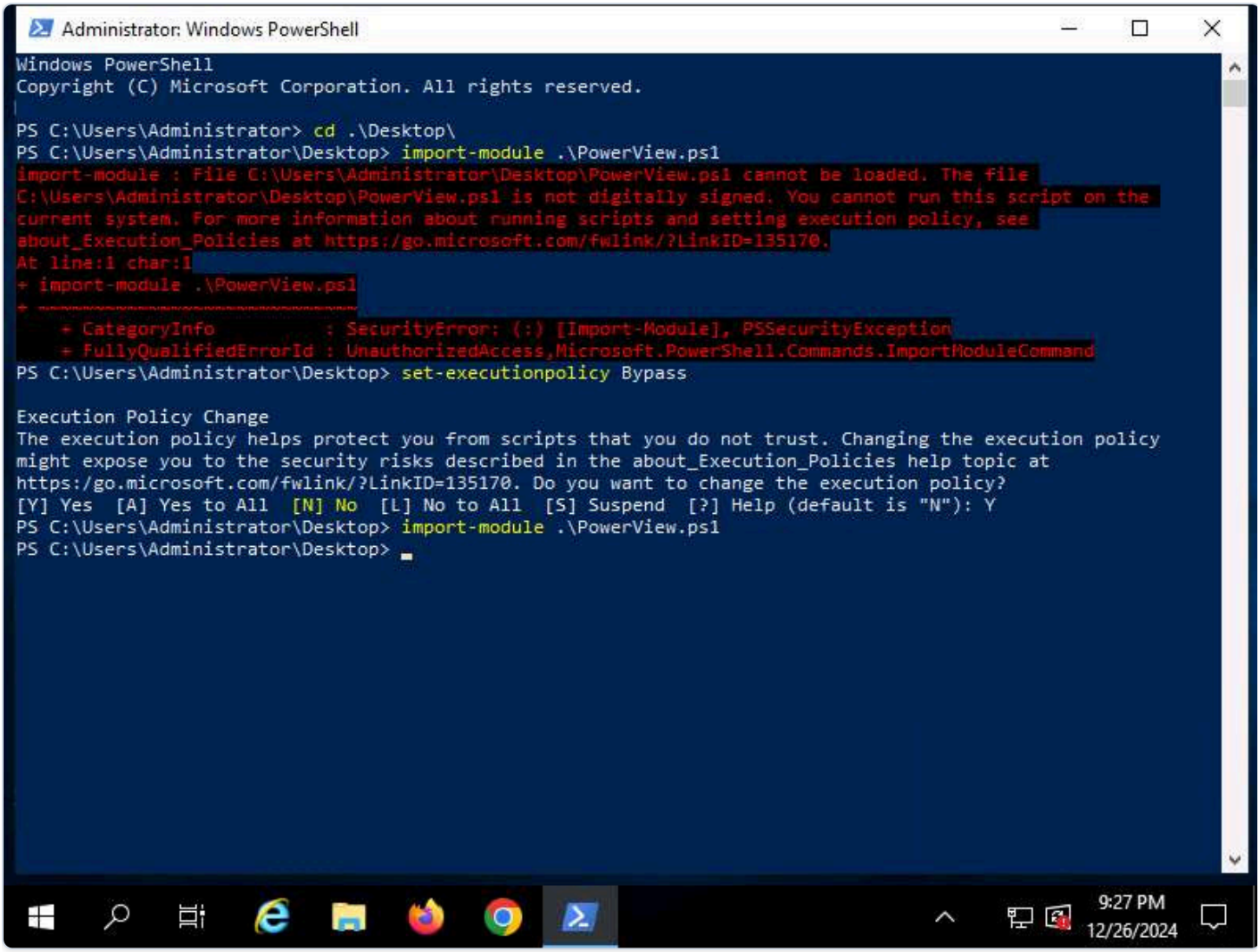
Observe error due to restricted execution policy.



1. Bypass execution policy restriction and import PowerView:

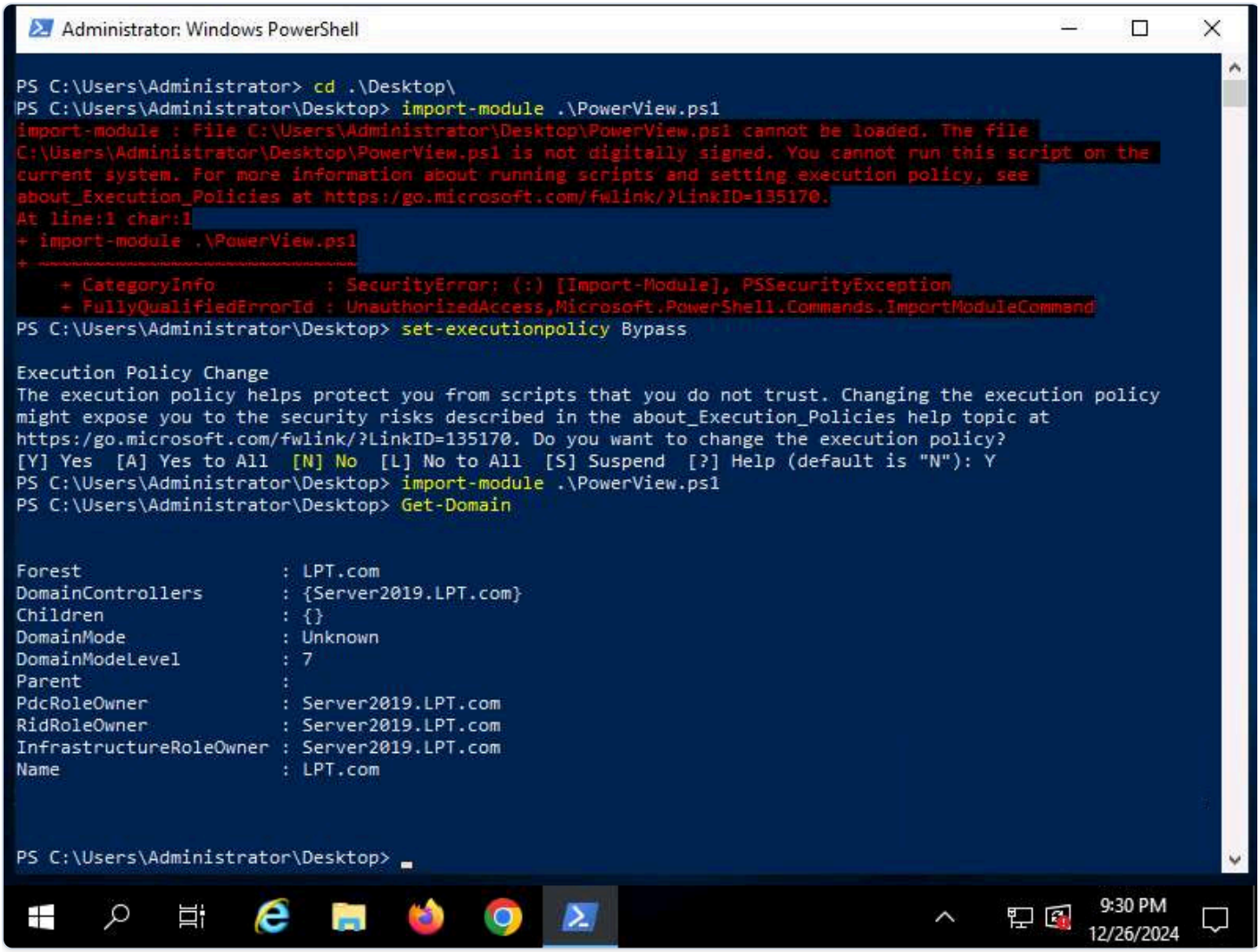
   set-executionpolicy Bypass

   import-module .\PowerView.ps1



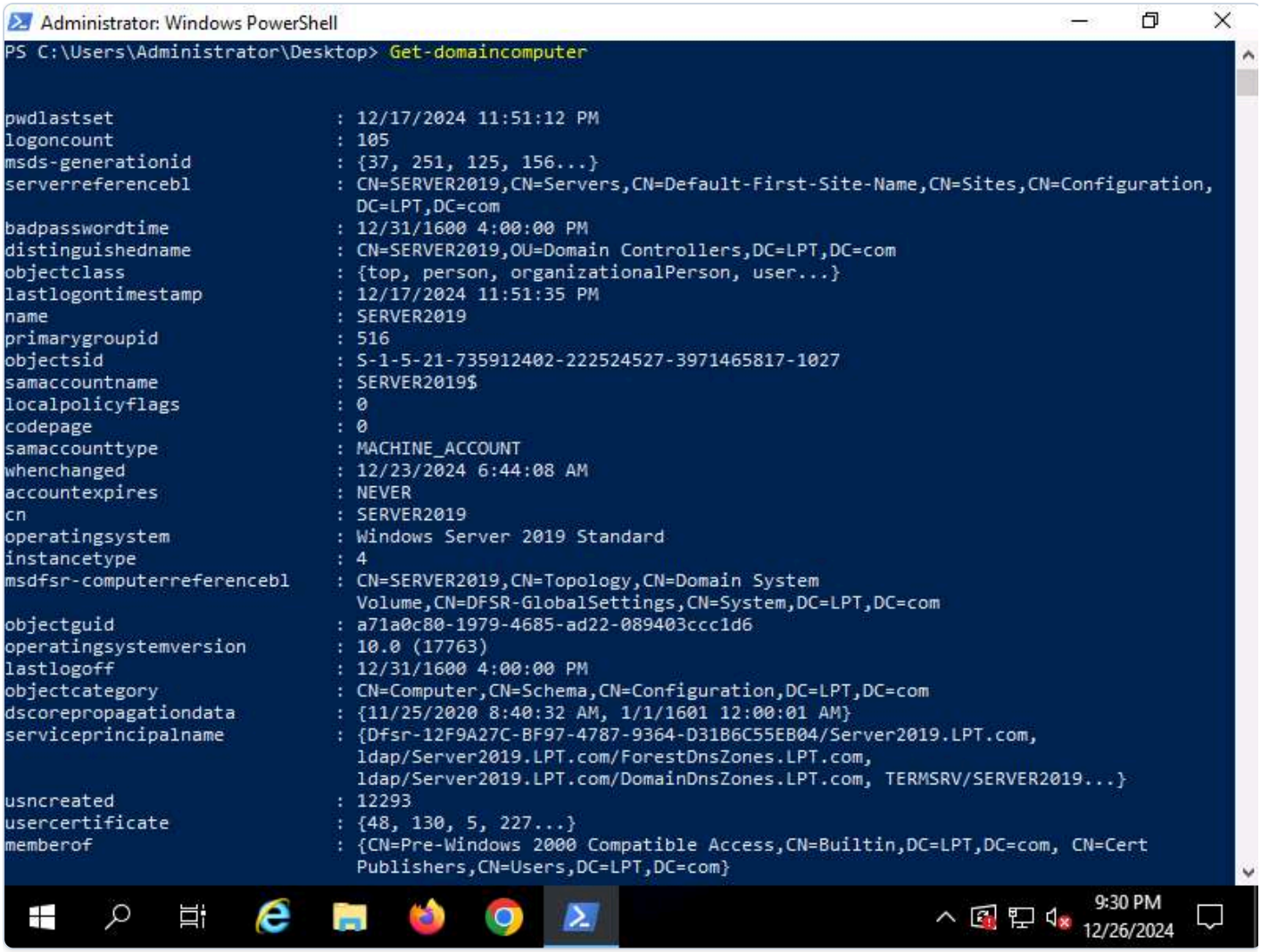
1. Retrieve general Active Directory domain details:

   Get-Domain

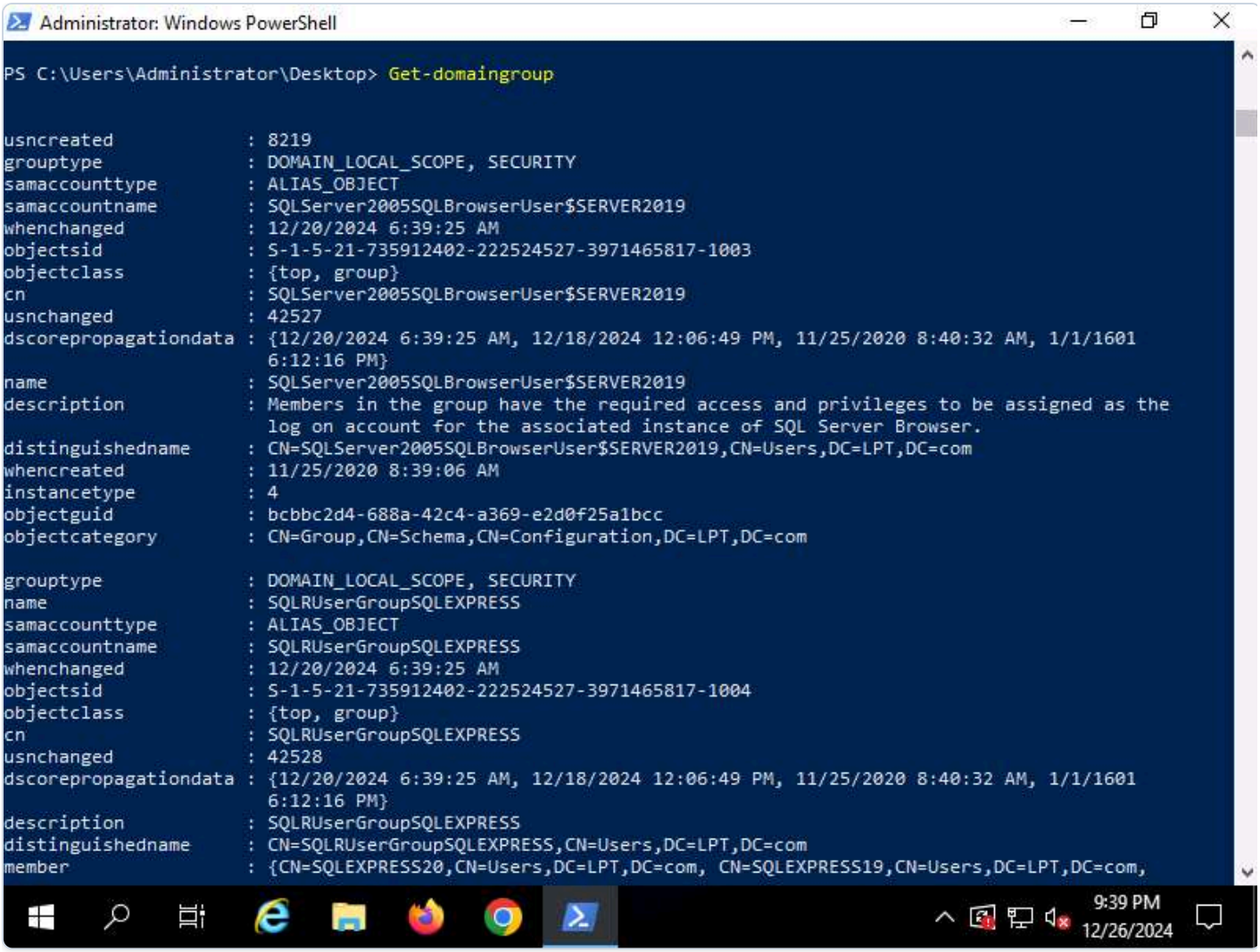


1. Enumerate all computer objects in the domain:

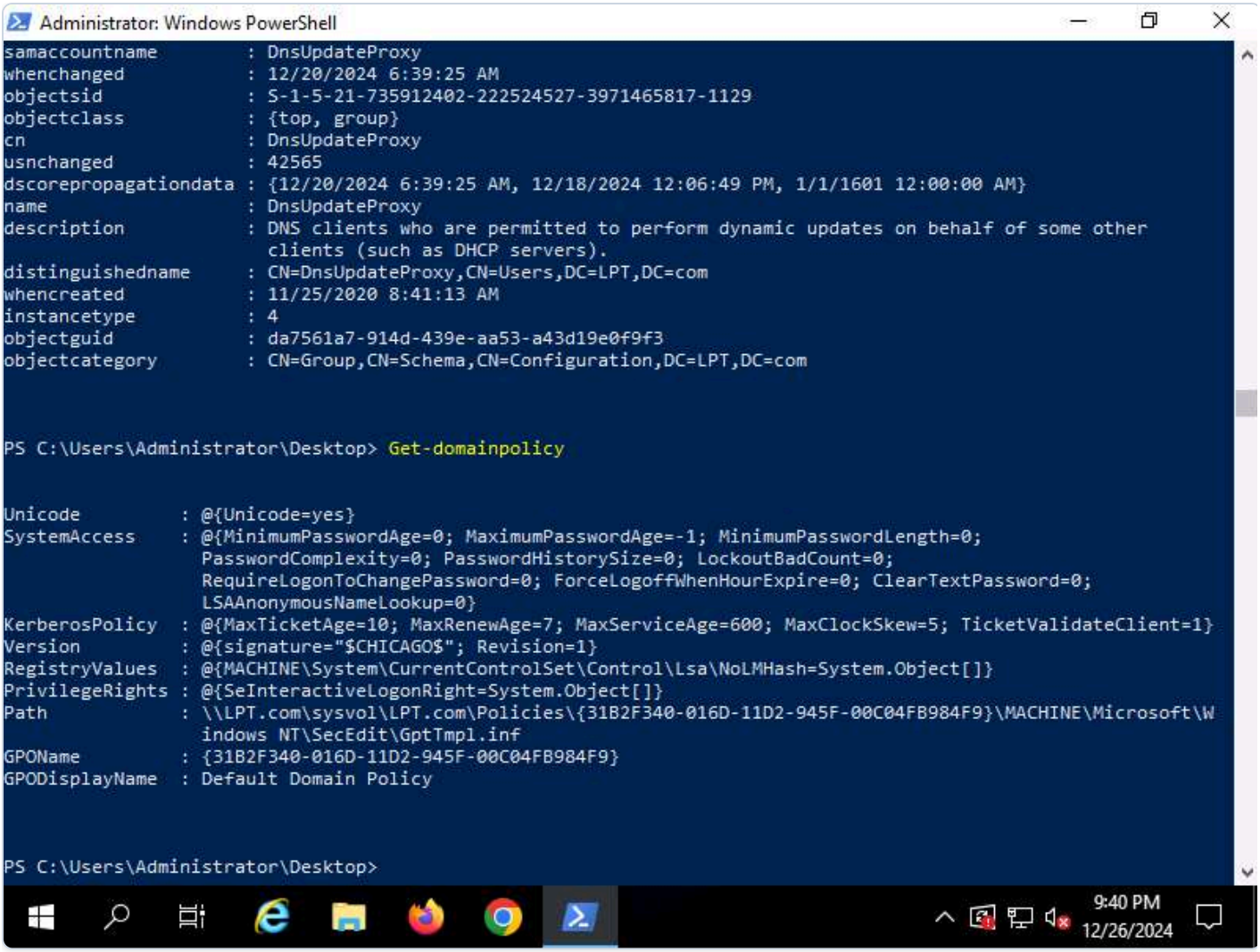
   Get-domaincomputer



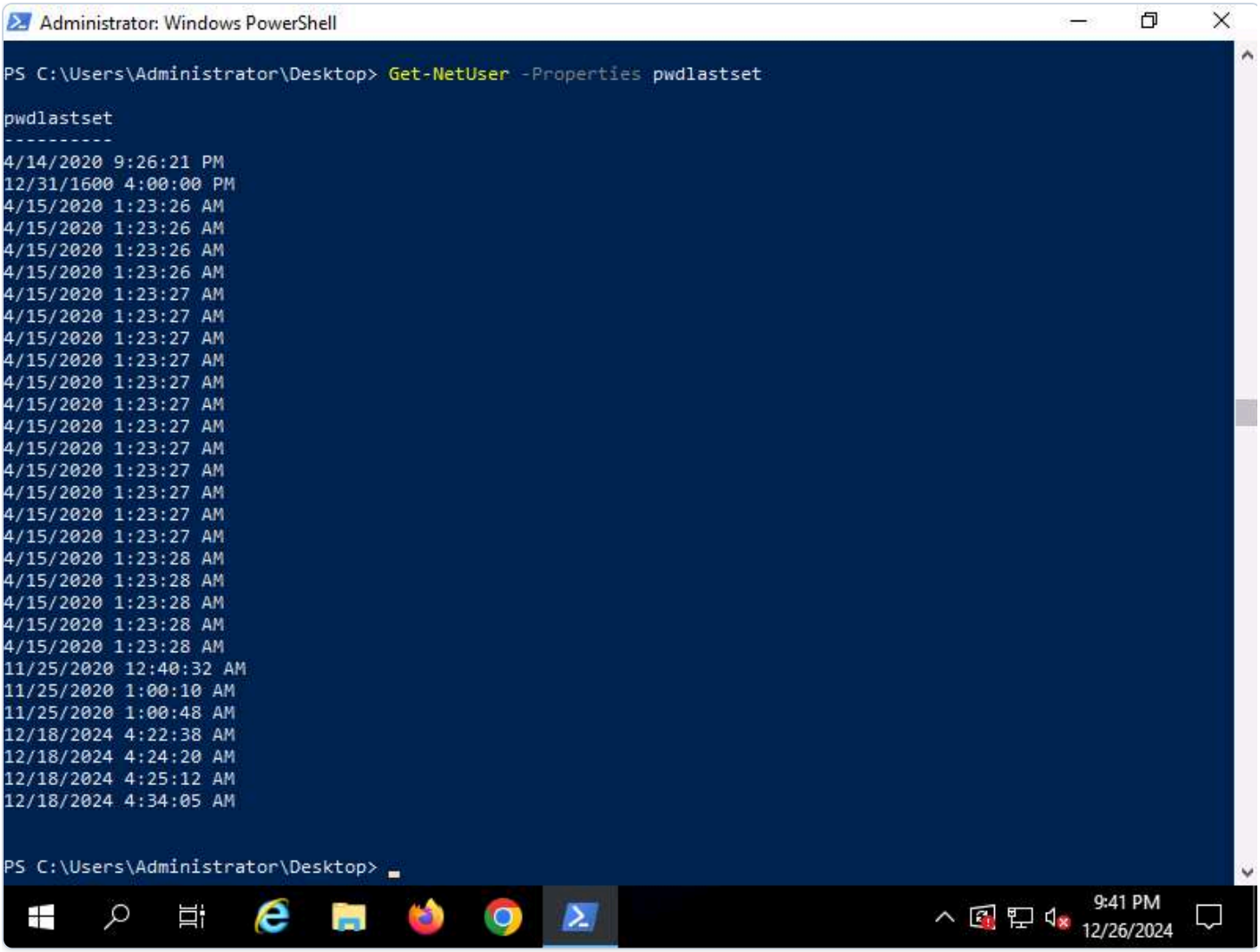
1. Review domain security groups:
   Get-domaingroup



1. Extract domain password, lockout, and Kerberos policies:
   Get-domainpolicy



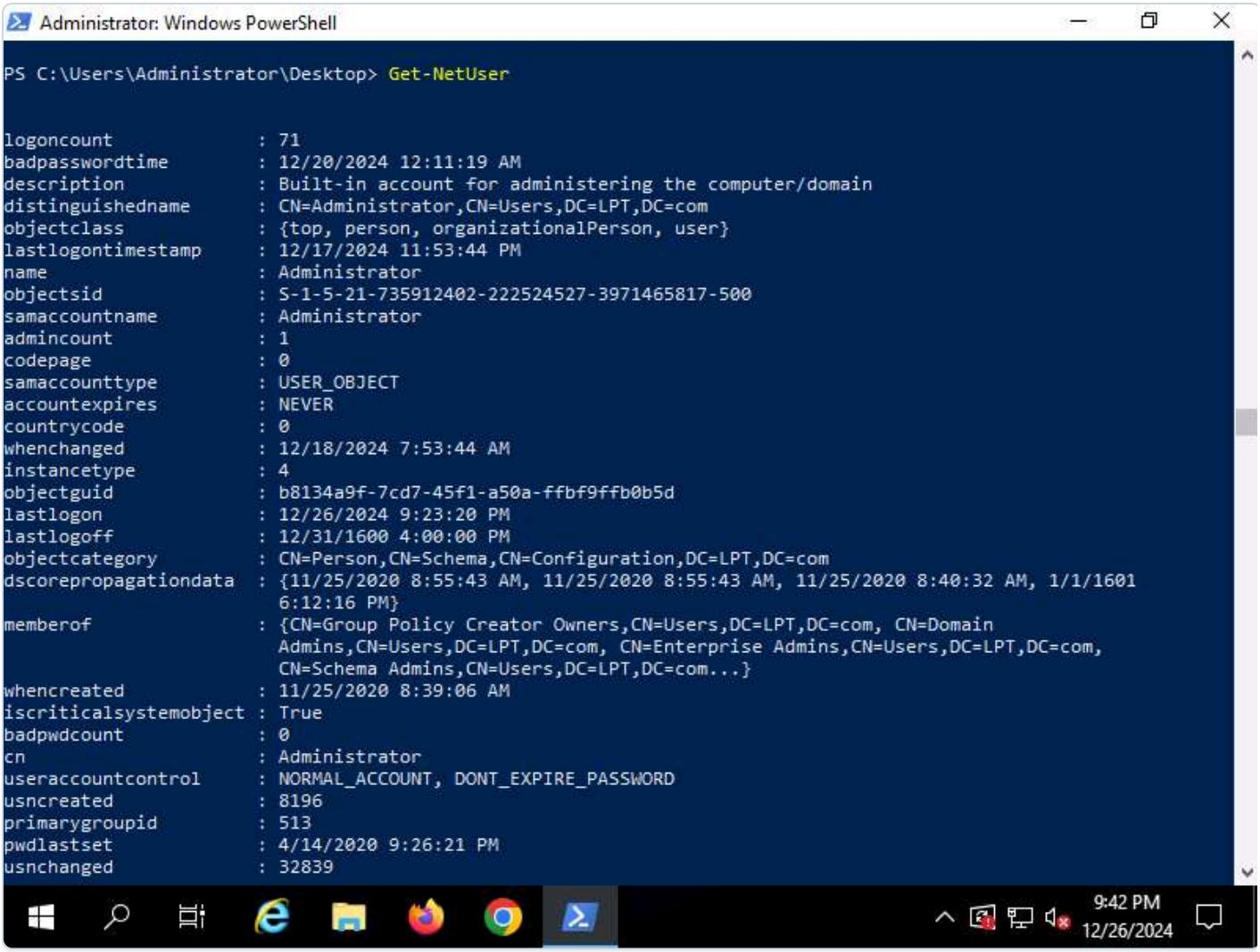
1. Extract password last set dates for all domain users in chronological order:
   Get-NetUser -Properties pwdlastset



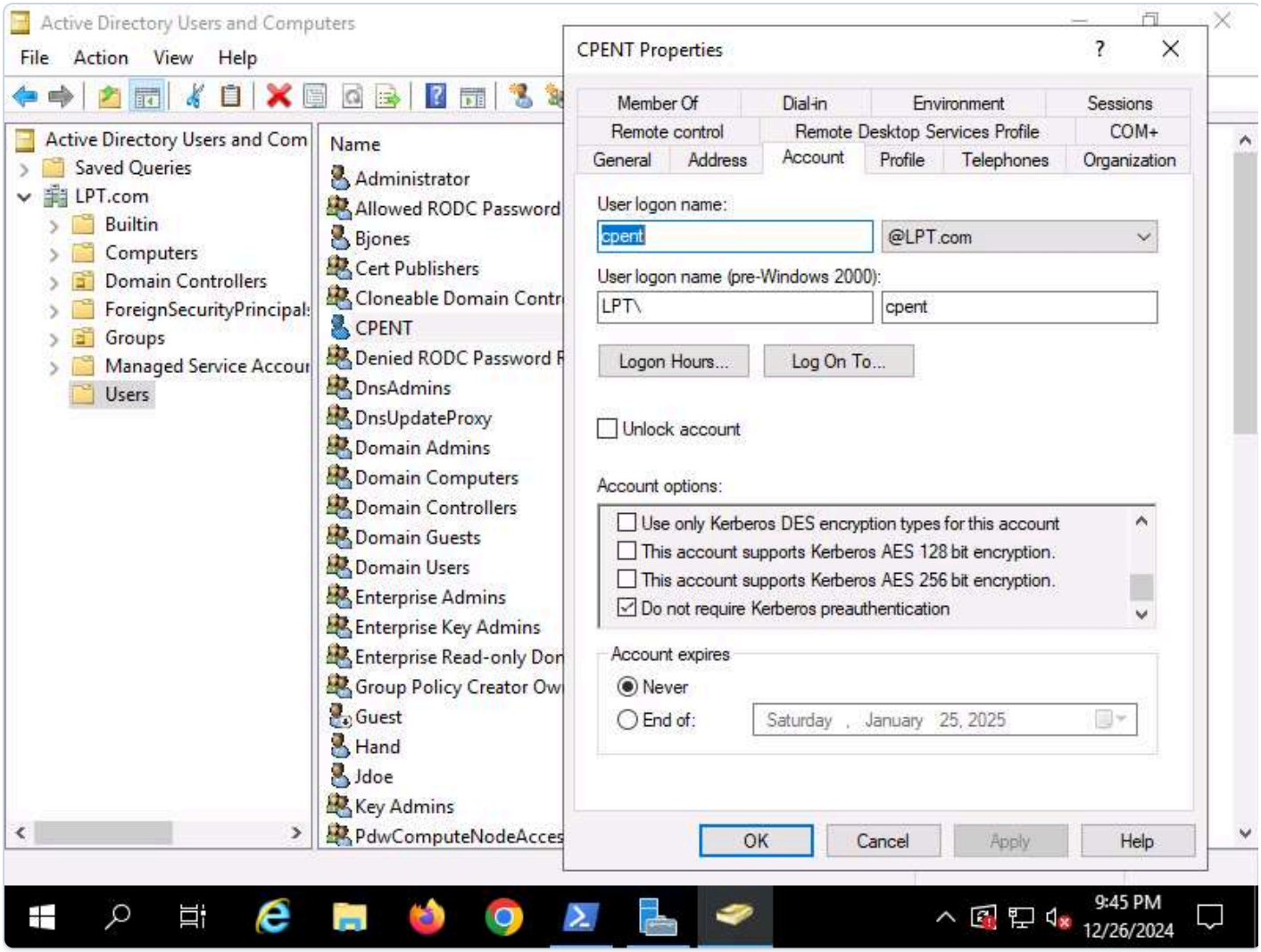
1. Enumerate domain user accounts and metadata:

   Get-NetUser

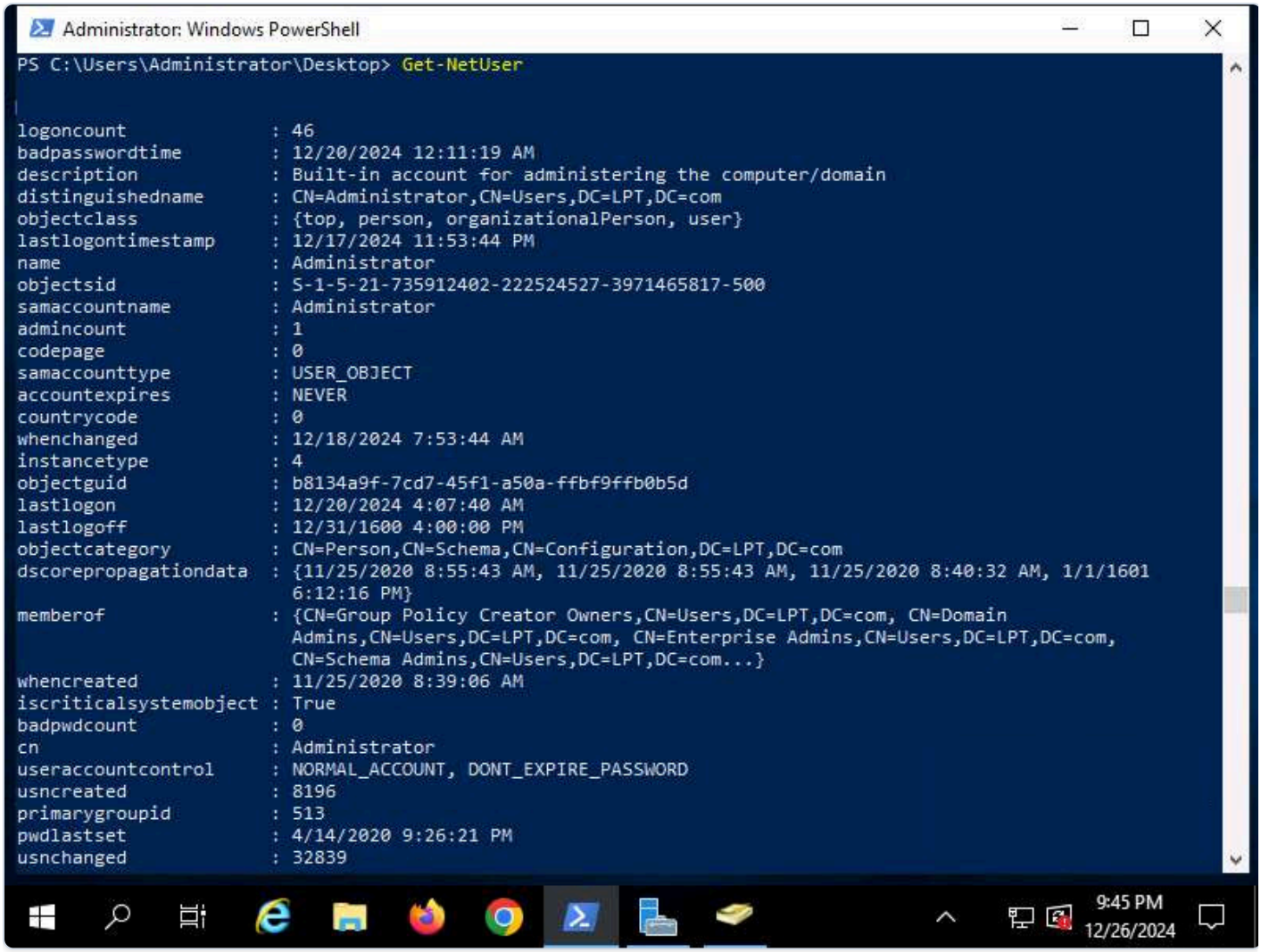
   Observe UserPrincipalName for `jdoe`*:* ***jdoe@lpt.com****.*

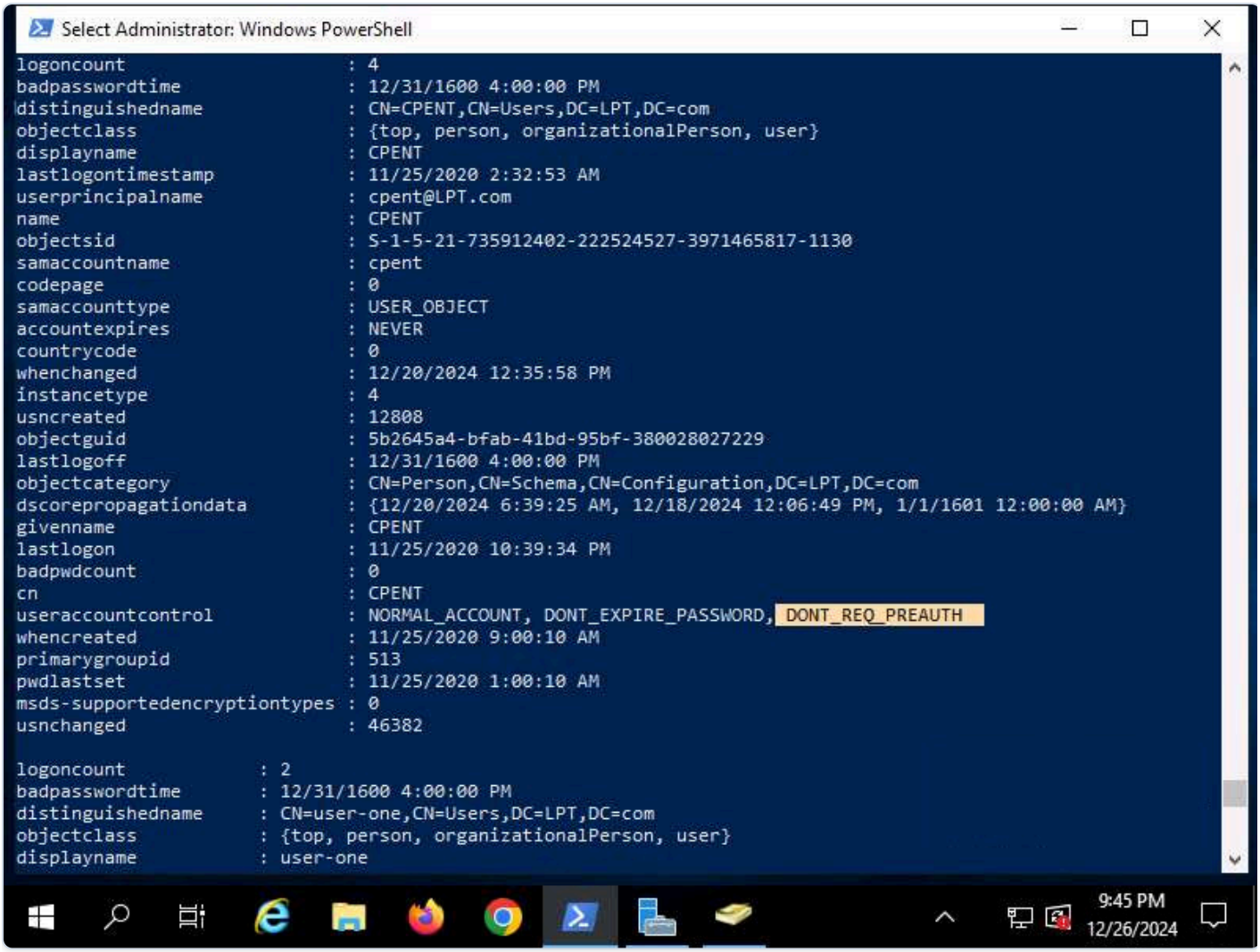


1. Open **Server Manager** $\rightarrow$ **Tools** $\rightarrow$ **Active Directory Users and Computers**. Navigate to `Groups`, right-click user `CPENT`, select **Properties** $\rightarrow$ **Account** tab, and check **Do not require Kerberos preauthentication**. Click **Apply** and **OK**.



1. Re-run `Get-NetUser` in PowerShell and inspect the `useraccountcontrol` field for account `CPENT` to detect the pre-authentication bypass flag (`DONT_REQUIRE_PREAUTH`).

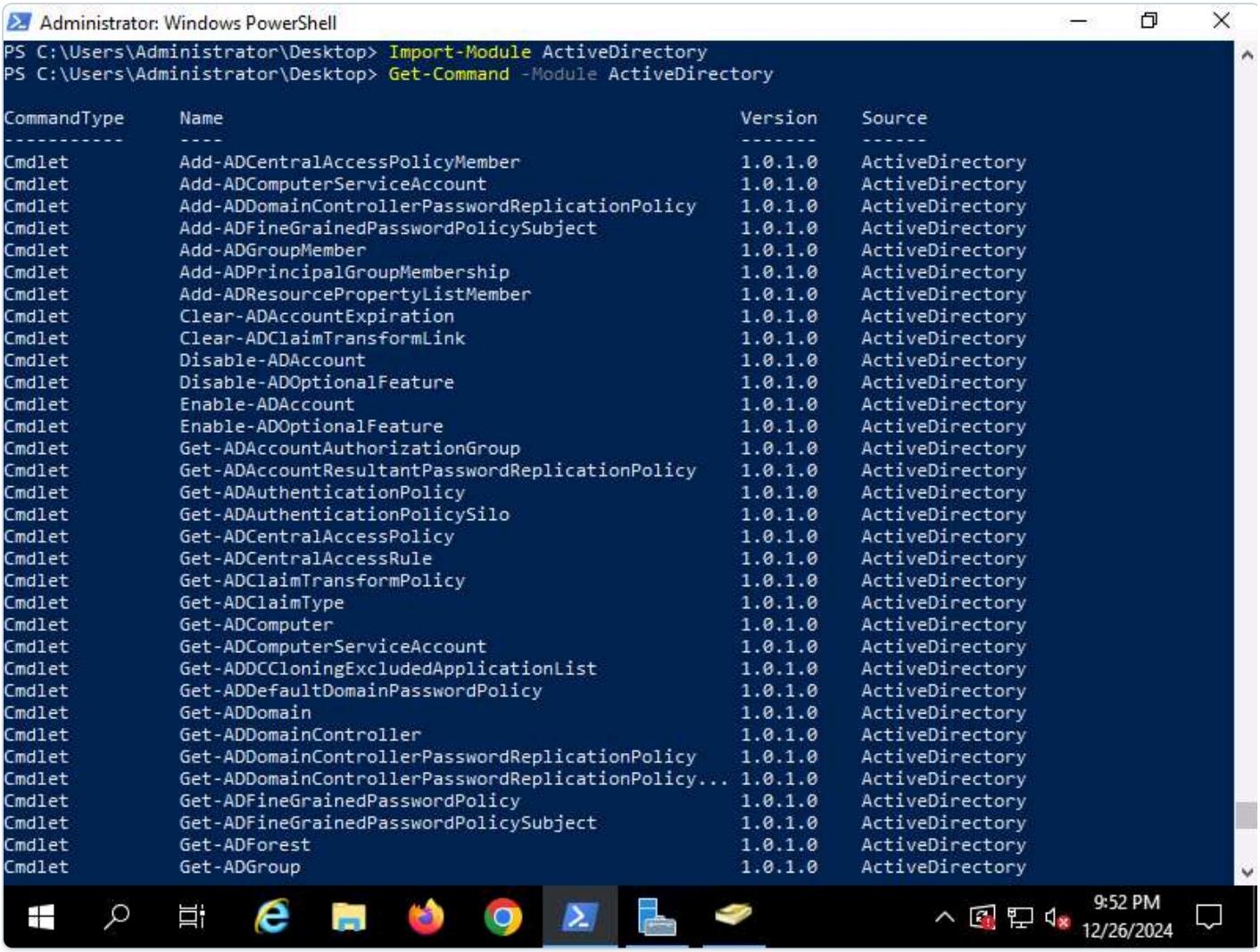

Administrator: Windows PowerShell
PS C:\Users\Administrator\Desktop> Get-NetUser
logoncount : 46
badpasswordtime : 12/20/2024 12:11:19 AM
description : Built-in account for administering the computer/domain
distinguishedname : CN=Administrator,CN=Users,DC=LPT,DC=com
objectclass : {top, person, organizationalPerson, user}
lastlogontimestamp : 12/17/2024 11:53:44 PM
name : Administrator
objectsid : S-1-5-21-735912402-222524527-3971465817-500
samaccountname : Administrator
admincount : 1
codepage : 0
samaccounttype : USER_OBJECT
accountexpires : NEVER
countrycode : 0
whenchanged : 12/18/2024 7:53:44 AM
instancetype : 4
objectguid : b8134a9f-7cd7-45f1-a50a-ffbf9ffb0b5d
lastlogon : 12/20/2024 4:07:40 AM
lastlogoff : 12/31/1600 4:00:00 PM
objectcategory : CN=Person,CN=Schema,CN=Configuration,DC=LPT,DC=com
dscorepropagationdata : {11/25/2020 8:55:43 AM, 11/25/2020 8:55:43 AM, 11/25/2020 8:40:32 AM, 1/1/1601 6:12:16 PM}
memberof : {CN=Group Policy Creator Owners,CN=Users,DC=LPT,DC=com, CN=Domain Admins,CN=Users,DC=LPT,DC=com, CN=Enterprise Admins,CN=Users,DC=LPT,DC=com, CN=Schema Admins,CN=Users,DC=LPT,DC=com...}
whencreated : 11/25/2020 8:39:06 AM
iscriticalsystemobject : True
badpwdcount : 0
cn : Administrator
useraccountcontrol : NORMAL_ACCOUNT, DONT_EXPIRE_PASSWORD
usncreated : 8196
primarygroupid : 513
pwdlastset : 4/14/2020 9:26:21 PM
usnchanged : 32839
9:45 PM
12/26/2024



1. Import native ActiveDirectory PowerShell module and list all available cmdlets:

   Import-Module ActiveDirectory

   Get-Command -Module ActiveDirectory



This concludes the lab exercise.

> **IMPORTANT:** ❓ **Question 9.4.1.1** In the 2019 DC machine, utilize PowerView.ps1 within Windows PowerShell to enumerate Active Directory objects, analyze domain policies, and identify Kerberos pre-authentication vulnerabilities. Specify the UserPrincipalName of the jdoe user for the enumeration process. [!SUCCESS] ✅
> **Answer:** **jdoe@lpt.com**